

Oversight of Reported Breaches of Data Protection Security

Date: 31-08-2023

Decision

Public Authorities

No Criticism

Supervision / Self-initiated Case

Report of Breach of Data Protection Security

The Data Protection Agency has conducted 16 planned inspections focusing on municipalities' and banks' handling of breaches of data protection security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-423-0243.

Guldborgsund Municipality was among the public authorities that the Data Protection Agency selected for oversight in the spring of 2021 under the General Data Protection Regulation [1] and the Data Protection Act [2].

The Data Protection Agency's oversight was a written inspection that focused on whether Guldborgsund Municipality had implemented appropriate security measures in accordance with Article 32, paragraph 1 of the General Data Protection Regulation, with the aim of reducing the number of breaches of data protection security involving unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

The inspection was announced by letter dated June 21, 2021, to Guldborgsund Municipality, and the municipality was simultaneously requested to respond to a number of questions and to submit an example of an instruction to the municipality's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc. The Data Protection Agency informed about the background for the inspection that, through a review of the agency's cases regarding reports of breaches of data protection security, it could be established that Guldborgsund Municipality had reported significantly more breaches of data protection security per inhabitant in the municipality than other municipalities in Denmark. The Data Protection Agency noted in this context that the higher number of reports does not necessarily indicate that the municipality complies with data protection regulations to a lesser extent than municipalities that have significantly fewer reports per inhabitant.

By letter dated August 26, 2021, Guldborgsund Municipality sent a statement in which the municipality responded to the Data Protection Agency's questions. The municipality's response was also accompanied by examples of relevant procedures and guidelines.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of data protection security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank, respectively.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of data protection security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of data protection security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is largely that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on

whether the municipalities and banks had implemented appropriate security measures to reduce the number of breaches of data protection security where unauthorized disclosure of personal data occurred in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons. The data controller must, in this context, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of data protection security.

The Data Protection Agency found on the basis of the information available that all data controllers had implemented appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no accidental disclosure of personal data to an incorrect recipient.

They have made considerations and continuously implemented both technical and organizational measures in response to past breaches of personal data security to avoid similar breaches. There is a strong focus on preventing unintended disclosure of confidential information, which is supported by business processes, ongoing guidance, etc., as well as systematic initiatives, etc.

****The Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security. The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules stipulating that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this context, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have conducted suitable training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including, among other things, the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that it had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training materials, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with.

Therefore, data controllers should document their justifications for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. Documentation regarding this decision should include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there has been pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security. In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018. The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on this, to consider whether, from a risk assessment perspective, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It is also evident from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds, on the basis of the existing information, that Guldborgsund Municipality has implemented appropriate security measures in accordance with Article 32, paragraph 1, of the General Data Protection Regulation, with the aim of reducing the number of breaches of personal data security involving unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

It is stated in Article 32, paragraph 1, of the General Data Protection Regulation that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing activities of personal data.

Thus, the data controller has an obligation to identify the risks that its processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. It is the opinion of the Data Protection Agency that the requirement under Article 32 for appropriate security will normally entail that the data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not become known to unauthorized persons, and that the data controller, in this context, must ensure that all employees in the organization are, to the necessary extent, familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc., and that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

Guldborgsund Municipality has, in its statement of August 26, 2021, submitted examples of instructions to the municipality's employees regarding the handling of personal data, including in connection with the transmission of information to, among others, citizens, authorities, etc. The municipality has stated that it continuously conducts awareness activities – e.g., training courses –

where there is a focus on breaches of personal data security, including unintentional disclosure of personal data and how to avoid this. The municipality has further stated that it is extremely aware of the risk of unintentional disclosure of confidential personal data about one parent (a child) to another parent.

It further appears from the case that Guldborgsund Municipality has considered the past breaches of personal data security, including by continuously reviewing workflows, as well as awareness activities and the adopted procedures contributing to this. The municipality has additionally stated that it continuously investigates the possibilities of implementing technical measures aimed at reducing the number of breaches of personal data security, where there has been unintentional disclosure of personal data.

It is – despite the fact that the Data Protection Agency has not had the opportunity to take a concrete position on whether all relevant employees have completed the relevant training activities, and that the agency is not familiar with the full content of all training materials, including the content of, for example, training courses – based on the present basis, the agency's assessment is that Guldborgsund Municipality has taken appropriate security measures in accordance with the General Data Protection Regulation (GDPR) Article 32, paragraph 1, aimed at reducing the number of breaches of personal data security, where there is unauthorized disclosure of personal data, including in relation to citizens with name and address protection.

In its assessment, the Data Protection Agency has placed emphasis on the information provided by the municipality, including that procedures, etc. have been developed and activities have been carried out aimed at educating employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient, that the municipality has considered and implemented measures following past breaches of personal data security to avoid similar breaches, and that there is a strong focus on avoiding unintentional disclosure of name and address protected information.

The Data Protection Agency can, upon a renewed review of the agency's cases regarding reports of breaches of personal data security, ascertain that since June 21, 2021, there has been a decrease in the number of reported breaches of personal data security from Guldborgsund Municipality. However, as there are still a number of reported breaches of personal data security where there has been unauthorized disclosure of personal data, the Data Protection Agency recommends that the municipality continues to focus on conducting training and awareness activities, etc., as well as ensuring that procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency finally notes that the agency – typically if it receives new reports of breaches of personal data security – may resume the processing of previously reported breaches or include them in the assessment of any future breach or complaint cases.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)